

WHITE PLAINS HOSPITAL HIPAA SECURITY RULE GAP ASSESSMENT April 2026											
☑ MET — Requirement fully satisfied		⚠ PARTIALLY MET — Gaps exist		✗ NOT MET — Requirement not addressed		Required = Mandatory Addressable = Risk-based		Use Ctrl+F to search Filters enabled on Row 5			
HIPAA Section	Req Type	Control Name	Requirement Description	Current State at WPH	Compliance Status	Gap Identified	Recommended Remediation	Priority	Responsible Owner	Target Date	% Complete
ADMINISTRATIVE SAFEGUARDS 45 CFR §164.308											
§164.308(a)(1)	Required	Security Management Process	Implement policies and procedures to prevent, detect, contain, and correct security violations.	Basic security policies exist but are not formally documented or regularly reviewed.	Partially Met	Formal security management program not established. No documented policy review schedule.	Establish formal security management program. Document all policies. Create quarterly review schedule.	Critical	CISO / GRC Analyst	May 2026	10%
§164.308(a)(1)(ii)(A)	Required	Risk Analysis	Conduct an accurate and thorough assessment of potential risks and vulnerabilities to ePHI.	No formal documented risk assessment has been conducted in the past 12 months.	Not Met	HIPAA requires annual documented risk analysis. No current risk assessment document exists.	Conduct formal annual risk assessment. Document findings in risk register. Report to leadership.	Critical	GRC Analyst	April 2026	0%
§164.308(a)(1)(ii)(B)	Required	Risk Management	Implement security measures sufficient to reduce risks and vulnerabilities to a reasonable level.	Some ad hoc security measures in place but no formal risk treatment plan or tracking.	Partially Met	Risk treatment plans are not formally documented or tracked. No risk register maintained.	Create and maintain formal risk register. Document treatment plans for all identified risks.	Critical	GRC Analyst	May 2026	10%
§164.308(a)(1)(ii)(C)	Required	Sanction Policy	Apply appropriate sanctions against workforce members who fail to comply with security policies.	HR disciplinary policy exists but does not specifically address ePHI security violations.	Partially Met	Sanction policy does not specifically cover ePHI violations or define escalating consequences.	Update HR disciplinary policy to include specific ePHI security violations and tiered consequences.	High	HR Manager / GRC Analyst	June 2026	10%
§164.308(a)(1)(ii)(D)	Required	Information System Activity Review	Implement procedures to regularly review records of information system activity.	Epic EHR audit logs are enabled but not reviewed on a regular scheduled basis.	Partially Met	No formal schedule for reviewing audit logs. Access anomalies not being detected proactively.	Implement monthly audit log review process. Assign Privacy Officer responsibility. Create review template.	High	Privacy Officer	May 2026	10%
§164.308(a)(2)	Required	Assigned Security Responsibility	Identify the security official responsible for developing and implementing security policies.	CISO role exists but GRC-specific responsibilities are not formally documented.	Partially Met	Security responsibility exists at CISO level but analyst-level GRC responsibilities not formally assigned.	Document formal security responsibility assignments. Establish GRC Analyst role with defined responsibilities.	Medium	CISO	May 2026	10%
§164.308(a)(3)(i)	Required	Workforce Authorization and Supervision	Implement procedures for authorization and supervision of workforce members who work with ePHI.	Managers provide verbal authorization for system access. No formal written authorization process.	Partially Met	No formal written authorization process for ePHI access. Access approvals not documented.	Implement formal written access authorization process. Document all ePHI access approvals.	High	IT Manager / HR Manager	June 2026	10%
§164.308(a)(3)(ii)(A)	Addressable	Authorization and Supervision	Implement procedures for authorizing access to ePHI consistent with job responsibilities.	Access is assigned by IT based on job title but no formal role-based access matrix exists.	Partially Met	No formal access matrix mapping job roles to required ePHI access levels.	Create role-based access control matrix. Map each job role to minimum necessary access level.	High	IT Manager	June 2026	10%
§164.308(a)(3)(ii)(B)	Addressable	Workforce Clearance Procedure	Implement procedures to determine that workforce members access is appropriate.	Background checks conducted at hiring but no ongoing clearance review process.	Partially Met	No periodic re-verification of workforce access appropriateness after initial hire.	Implement quarterly user access reviews. Verify access remains appropriate for current job function.	Medium	HR Manager / IT Manager	July 2026	10%
§164.308(a)(3)(ii)(C)	Addressable	Termination Procedures	Implement procedures for terminating access when employment ends.	IT account deactivation is manual and sometimes delayed. No formal offboarding checklist.	Partially Met	Former employee accounts not consistently deactivated at termination. No documented procedure.	Create formal IT offboarding checklist. Automate account deactivation. Audit monthly for orphaned accounts.	High	IT Manager / HR Manager	May 2026	10%
§164.308(a)(4)(i)	Required	Information Access Management	Implement policies and procedures for authorizing access to ePHI.	Access management policies exist but are not formally documented with clear authorization requirements.	Partially Met	Information access management policy lacks specificity on ePHI authorization requirements.	Document comprehensive information access management policy with ePHI-specific requirements.	High	Privacy Officer / GRC Analyst	June 2026	10%
§164.308(a)(4)(ii)(B)	Addressable	Access Authorization	Implement policies and procedures for granting access to a workstation, transaction, or ePHI.	Access authorization is informal and undocumented. Approvals given verbally by managers.	Not Met	No formal documented access authorization workflow for ePHI systems.	Implement formal access request and authorization workflow with documented approvals and review.	High	IT Manager	June 2026	0%
§164.308(a)(5)(i)	Required	Security Awareness and Training	Implement a security awareness and training program for all workforce members.	Annual HIPAA training is conducted but cybersecurity-specific awareness training is lacking.	Partially Met	Training program does not cover current threats including phishing, ransomware, and social engineering.	Expand training program to include cybersecurity awareness. Add phishing simulation exercises quarterly.	Critical	HR Manager / GRC Analyst	May 2026	10%
§164.308(a)(5)(ii)(B)	Addressable	Protection from Malicious Software	Implement procedures for guarding against, detecting, and reporting malicious software.	Basic antivirus installed on workstations. No EDR solution. Staff awareness of malware is low.	Partially Met	Antivirus is basic and outdated on some devices. No advanced endpoint detection in place.	Deploy enterprise EDR solution. Implement malware awareness in training program. Establish reporting procedure.	Critical	IT Manager	June 2026	10%
§164.308(a)(5)(ii)(C)	Addressable	Log-in Monitoring	Implement procedures for monitoring log-in attempts and reporting discrepancies.	Epic EHR logs login attempts but no monitoring for unusual patterns or failed attempts.	Partially Met	No automated alerting for suspicious login patterns or after-hours access.	Configure automated alerts for failed login attempts and after-hours access. Assign monitoring owner.	High	IT Manager	June 2026	10%

§164.308(a)(5)(ii)(D)	Addressable	Password Management	Implement procedures for creating, changing, and safeguarding passwords.	Password policy exists on paper but technical enforcement is inconsistent across systems.	Partially Met	Password complexity and expiration not technically enforced on all hospital systems.	Enforce password policy technically on all systems. Implement MFA. Deploy enterprise password manager.	Critical	IT Manager	May 2026	10%
§164.308(a)(6)(i)	Required	Security Incident Procedures	Implement policies and procedures to address security incidents.	No formal written incident response plan exists. Incidents handled informally by IT.	Not Met	No documented incident response plan. Staff do not know escalation procedures.	Develop formal incident response plan. Define roles, procedures, and communication protocols. Conduct tabletop exercise.	Critical	GRC Analyst / CISO	May 2026	0%
§164.308(a)(7)(i)	Required	Contingency Plan	Establish policies and procedures for responding to emergency operations and protecting ePHI.	No formal business continuity or disaster recovery plan exists for ePHI systems.	Not Met	No documented contingency plan. No defined RTO or RPO. Backup procedures untested.	Develop contingency plan with defined RTO and RPO. Document backup procedures. Test annually.	Critical	IT Manager / GRC Analyst	July 2026	0%
§164.308(a)(7)(ii)(A)	Required	Data Backup Plan	Establish procedures to create and maintain retrievable exact copies of ePHI.	Manual backups are performed but schedule is inconsistent. No offsite or cloud backup.	Partially Met	Backup process is manual and inconsistent. No offsite backup copy maintained.	Implement automated daily cloud backup. Verify backup integrity monthly. Document backup procedures.	Critical	IT Manager	May 2026	10%
§164.308(a)(8)	Required	Evaluation	Perform a periodic technical and nontechnical evaluation of security practices.	No formal scheduled evaluation process. Last assessment was informal and undocumented.	Not Met	No annual formal evaluation of security practices against HIPAA requirements.	Implement annual HIPAA Security Rule evaluation. Document findings. Report to leadership.	High	GRC Analyst	July 2026	0%
PHYSICAL SAFEGUARDS 45 CFR §164.310											
§164.310(a)(1)	Required	Facility Access Controls	Implement policies and procedures to limit physical access to ePHI systems.	Server room has a basic door lock. No key card access system. No visitor log maintained.	Not Met	No key card access control on server room. No formal physical access procedures documented.	Install key card access on server room. Implement visitor log. Document physical access procedures.	High	Facilities Manager / IT Manager	July 2026	0%
§164.310(a)(2)(ii)	Addressable	Facility Security Plan	Implement policies and procedures to safeguard facilities from unauthorized physical access.	General building security exists but no ePHI-specific facility security plan is documented.	Partially Met	No documented facility security plan specifically addressing ePHI system locations.	Document facility security plan covering server room, workstation areas, and clinical systems.	Medium	Facilities Manager	August 2026	10%
§164.310(b)	Required	Workstation Use	Implement policies and procedures that specify proper functions of workstations with ePHI.	Workstation use policy exists in the AUP but workstation-specific ePHI procedures are lacking.	Partially Met	No specific procedures for workstation use in clinical areas with ePHI access.	Develop workstation use procedures for clinical areas. Include clean desk and screen lock requirements.	Medium	GRC Analyst / IT Manager	June 2026	10%
§164.310(c)	Required	Workstation Security	Implement physical safeguards for all workstations that access ePHI.	Workstations have automatic screen locks configured. Some clinical workstations lack privacy screens.	Partially Met	Screen lock policy in place but privacy screens not deployed in high-traffic clinical areas.	Deploy privacy screens on workstations in high-traffic areas. Verify screen lock settings on all devices.	Medium	IT Manager	July 2026	10%
§164.310(d)(1)	Required	Device and Media Controls	Implement policies and procedures for final disposition of ePHI and hardware on which it resides.	No formal media disposal policy. Old devices are reused or discarded without certified data destruction.	Not Met	No formal device disposal process. ePHI potentially accessible on retired hardware.	Implement certified data destruction process for all retired devices. Document disposal records.	High	IT Manager	June 2026	0%
TECHNICAL SAFEGUARDS 45 CFR §164.312											
§164.312(a)(1)	Required	Access Control	Implement technical policies and procedures for electronic information systems containing ePHI.	Role-based access implemented in Epic EHR but not consistently enforced across all systems.	Partially Met	Access control not consistently implemented across all systems containing ePHI.	Implement role-based access control across all ePHI systems. Enforce minimum necessary access.	Critical	IT Manager	May 2026	10%
§164.312(a)(2)(i)	Required	Unique User Identification	Assign a unique name or number for identifying and tracking user identity.	Unique logins required in Epic EHR but some shared accounts exist on legacy systems.	Partially Met	Shared accounts identified on legacy clinical systems. Not all ePHI access is individually tracked.	Eliminate all shared accounts. Assign unique identifiers to all users on all ePHI systems.	Critical	IT Manager	May 2026	10%
§164.312(a)(2)(iii)	Addressable	Automatic Logoff	Implement electronic procedures that terminate an electronic session after inactivity.	Automatic logoff is configured on most workstations but not on all clinical devices.	Partially Met	Automatic logoff not consistently configured across all clinical workstations and devices.	Verify and enforce automatic logoff settings on all workstations and clinical devices. Set maximum 10 minutes.	Medium	IT Manager	June 2026	10%
§164.312(a)(2)(iv)	Addressable	Encryption and Decryption	Implement mechanisms to encrypt and decrypt ePHI.	Encryption applied to laptops and some servers. Email encryption for PHI not consistently enforced.	Partially Met	Email encryption for PHI transmission not consistently enforced. Some storage not encrypted.	Implement full disk encryption on all devices. Enforce encrypted email for all PHI communications.	High	IT Manager	June 2026	10%
§164.312(b)	Required	Audit Controls	Implement hardware, software, or procedural mechanisms to record and examine activity on systems with ePHI.	Epic EHR audit logging is enabled. Log review process is informal and infrequent.	Partially Met	Audit logs enabled but no formal review schedule or process. Anomalies may go undetected.	Formalize audit log review process. Schedule monthly reviews. Document findings and escalate anomalies.	High	Privacy Officer / GRC Analyst	May 2026	10%
§164.312(c)(1)	Required	Integrity	Implement policies and procedures to protect ePHI from improper alteration or destruction.	Database integrity controls exist within Epic EHR. No additional integrity monitoring in place.	Partially Met	Integrity controls limited to EHR application. No independent integrity monitoring for all ePHI systems.	Implement file integrity monitoring across all ePHI systems. Document integrity controls.	Medium	IT Manager	July 2026	10%

§164.312(d)	Required	Person or Entity Authentication	Implement procedures to verify that a person seeking access is who they claim to be.	Username and password authentication in place. MFA not deployed on all ePHI systems.	Partially Met	MFA not universally deployed. Authentication relies solely on password for some systems.	Deploy MFA on all systems containing ePHI. Prioritize Epic EHR and remote access.	Critical	IT Manager	May 2026	10%
§164.312(e)(1)	Required	Transmission Security	Implement technical security measures to guard against unauthorized access during transmission.	HTTPS used for web-based systems. Some internal transmissions not encrypted.	Partially Met	Internal network transmissions of ePHI not consistently encrypted. Email PHI sent unencrypted.	Implement TLS encryption for all internal ePHI transmissions. Enforce encrypted email for PHI.	High	IT Manager	June 2026	10%
ORGANIZATIONAL REQUIREMENTS 45 CFR §164.314											
§164.314(a)(1)	Required	Business Associate Contracts	A covered entity must obtain satisfactory assurances from business associates that ePHI will be protected.	Some vendor contracts exist but BAA compliance has not been verified across all vendors.	Not Met	BAAs not confirmed for all vendors handling ePHI. No vendor BAA tracking process in place.	Audit all vendor contracts for BAA compliance. Obtain missing BAAs. Implement vendor BAA tracker.	Critical	GRC Analyst / Legal	May 2026	0%
POLICIES AND PROCEDURES 45 CFR §164.316											
§164.316(a)	Required	Policies and Procedures	Implement reasonable and appropriate policies and procedures to comply with HIPAA Security Rule.	Some policies exist but are incomplete and not consistently enforced or reviewed.	Partially Met	Policy suite is incomplete. Existing policies not reviewed on a regular schedule.	Complete policy suite development. Implement annual policy review schedule. Track acknowledgments.	High	GRC Analyst / CISO	June 2026	10%
§164.316(b)(1)	Required	Documentation	Maintain written security policies and procedures and retain for 6 years.	Documentation is scattered and not centrally managed. Retention policy not enforced.	Not Met	No centralized document management. Retention period for security documentation not enforced.	Implement centralized document management system. Apply 6-year retention policy to all security documentation.	High	GRC Analyst	July 2026	0%
CONFIDENTIAL White Plains Hospital GRC Program Nadhir Choudhury Educational purposes only											